

无线通信安全开卷考试合并终版

按往年大题风格修订：知识点速查 + 精准预测 + 答题模板

根据课件、课堂纪要与复习需求整理

2026 年 6 月 22 日

目录

0. 开卷考试先看这一页	5
无线通信安全的万能分析框架	5
万能分析段落	5
高概率大题预测精准版	6
预测 1: WCDMA/3G 安全体系结构与 AKA	6
预测 2: LTE NAS/AS 分层、eNB 风险与密钥层次	6
预测 3: 5G SUPI/SUCI、5G-AKA 与身份隐私	7
预测 4: LTE 用户面完整性缺口与 5G 改进	7
预测 5: 2G 到 5G 安全演进综合比较	7
预测 6: 综合分析题	8
预测 7: 5G 切片、SEPP、SBA	8
预测 8: 综合设计题	8
预测 9: WLAN/WEP 与四次握手	9
预测 10: GSM 缺陷与伪基站	10
预测 11: TETRA 空口加密与端到端加密同步区别	10
1 第一讲：课程概述与无线安全发展	10
1.1 本章可能考法	11
1.2 安全目标	11
1.3 无线安全发展历史	11
2 第二讲：密码学基础与认证理论	12
2.1 本章可能考法	12
2.2 基本概念	13
2.3 密码体制分类	13
2.4 密码分析攻击类型	13

2.5	分组密码模式	14
2.6	只加密不安全	14
3	第三讲：无线通信威胁与安全体系	14
3.1	本章可能考法	15
3.2	威胁分类	15
3.3	三类主要威胁	15
3.4	安全服务、需求、域	15
3.5	安全域	16
4	第四讲：WLAN 安全	17
4.1	本章可能考法	17
4.2	WLAN 安全目标	17
4.3	WEP 机制	17
4.4	WEP 缺陷	17
4.5	802.1X/EAP 与四次握手	18
4.6	WEP/WPA/WPA2/WPA3 对比	18
4.7	常见攻击与改进	18
5	第五讲：GSM 安全	19
5.1	本章可能考法	19
5.2	GSM 网络实体	19
5.3	GSM 安全机制	20
5.4	鉴权和密钥生成	20
5.5	匿名机制	20
5.6	GSM 缺陷	20
6	第六讲：TETRA 安全	21
6.1	本章可能考法	21
6.2	TETRA 安全需求	22
6.3	识别码	22
6.4	安全等级	22
6.5	鉴权	22
6.6	三种加密	22
6.7	TETRA 鉴权协议分析	23
7	第七讲：WCDMA 安全	23
7.1	本章可能考法	23
7.2	3G 安全原则	24
7.3	3G 安全体系结构	24
7.4	AKA 的目的	24

7.5	认证向量 AV	24
7.6	TMSI 再分配	25
7.7	WCDMA 与 GSM 对比	25
7.8	WCDMA 不足	25
8	第八讲：LTE 安全	26
8.1	本章可能考法	26
8.2	LTE 安全威胁	26
8.3	LTE 安全要求	26
8.4	NAS 和 AS 分层	27
8.5	匿名机制	27
8.6	LTE 密钥层次	27
8.7	切换安全	27
8.8	LTE 典型缺陷和攻击	28
9	第九讲：5G 网络安全	28
9.1	本章可能考法	28
9.2	5G 安全增强	29
9.3	SUPI 与 SUCI	29
9.4	5G-AKA 与密钥层次	29
9.5	用户面完整性	30
9.6	切片安全	30
9.7	SEPP 与漫游安全	30
9.8	SBA 安全	30
9.9	5G-AKA 可能问题	30
10	第十讲：课程总结与未来无线安全	31
10.1	本章可能考法	31
10.2	2/3/4/5G 横向对比	31
10.3	加密和完整性终结点演进	32
10.4	切换安全演进	32
10.5	未来无线安全	32
10.6	未来安全方向	33
11	综合分析题专项模板	33
11.1	题型一：只加密用户面，不做完整性，不检查序列号	33
11.2	题型二：方案使用永久身份明文接入	33
11.3	题型三：方案只有网络认证用户，没有用户认证网络	34
11.4	题型四：方案长期使用同一密钥	34
11.5	题型五：切换过程中直接把旧密钥给新基站	34

目录	4
最后考前速查	34

0. 开卷考试先看这一页

这份资料不是普通笔记，而是给开卷考试用的。开卷考试最怕两件事：第一，资料很多但翻不到；第二，翻到了也不知道怎么组织答案。所以每一章都按下面逻辑写：

1. 这章到底讲什么。
2. 可能怎么出大题。
3. 大题应该按什么顺序写。
4. 关键机制、缺陷、改进建议。

无线通信安全的万能分析框架

无论题目问 WLAN、GSM、WCDMA、LTE、5G，还是给一个陌生方案让你分析，都可以先检查这 8 项：

检查项	考场怎么写
身份隐私	是否明文暴露 IMSI/SUPI/永久身份？是否使用 TMSI/GUTI/SUCI 等临时或加密身份？是否能被长期跟踪？
认证	是否双向认证？网络能否认证用户，用户能否认证网络？能否防伪基站、中间人？
机密性	是否加密空口、核心网信令、用户数据？加密终结点在哪里？
完整性	是否对信令/用户面做 MAC 或认证标签？只加密不能防篡改。
新鲜性	是否使用随机数、序列号、计数器、SQN、COUNT 防重放？
密钥管理	密钥如何生成、派生、更新？是否一钥多用？是否分层？泄露影响多大？
切换/漫游	手机移动、切换基站、跨运营商漫游时，安全上下文是否安全转移或更新？
降级/DoS	是否可被迫使用弱算法、弱网络？错误消息、重同步、去认证、寻呼等是否可被利用？

万能分析段落

该方案只考虑了部分安全目标，没有形成完整的无线通信安全机制。无线信道开放，攻击者不仅可以被动窃听，还可以主动篡改、插入、删除、重放或伪造消息。因此系统不能只依赖加密，还应同时提供身份认证、完整性保护、新鲜性检查、身份隐私保护和密钥更新机制。若缺少双向认证，可能遭受伪基站或中间人攻击；若缺少完整性保护，攻击者可修改控制信令或密文数据；若缺少随机数、序列号或计数器，旧消息可能被重放；若永久身份明文传输，用户可能被定位和跟踪；若密钥长期不变或一钥多用，密钥泄露后的影响范围会扩大。改进时应采用标准 AKA/认证密钥协商协议，使用 KDF 派生不同用途的会话密钥，对身份、算法标识、方

向、承载、序列号、IV/Nonce 和密文进行 MAC 或认证加密保护，并在切换和漫游场景下更新安全上下文。

高概率大题预测精准版

老师课堂纪要里强调：题目不要只答两句话，要围绕安全目标发散。结合往年题风格，期末大题通常不是让你背定义，而是让你写“原理 + 缺陷 + 为什么 + 改进建议”。10 分题多考一个点讲清楚；15 分题多考优缺点或能否实现；20 分题多给一个方案让你分析和改进。下面按这种风格重写，考场优先翻这一节。

预测 1: WCDMA/3G 安全域、AKA 与切换认证 (10–15 分)

可能题目：说明 3G/WCDMA 的安全域和 AKA 认证机制。为什么移动到新基站或新服务网时可能需要重新认证或更新安全上下文？

考试答案：3G 安全体系可从接入域、网络域、用户域、应用域以及安全可见性/可配置性来写。接入域解决 UE 通过无线空口接入网络时的认证、加密、完整性和身份保护；网络域解决核心网节点之间的安全；用户域保护 USIM 与用户使用；应用域保护端到端应用。AKA 的核心目的有四个：网络认证用户、用户认证网络、产生会话密钥、保证认证消息新鲜。

认证向量为 $AV = (RAND, XRES, CK, IK, AUTN)$ 。 $RAND$ 是随机挑战， $XRES$ 是网络侧期望响应， CK 是加密密钥， IK 是完整性密钥， $AUTN$ 让 UE 验证网络。 $AUTN$ 中 MAC 证明认证令牌来自知道长期密钥的归属网，SQN 用于防重放，AK 用于隐藏 SQN。相比 GSM，WCDMA 从单向认证变为双向认证，从单一 K_c 变为 CK/IK 分离，并增加信令完整性保护。

如果题目问“每换一个基站为什么要重新认证”，不要绝对写成每次都完整 AKA。更稳妥的写法是：切换时 UE 面临新的接入点或服务网，必须保证目标网络合法、密钥新鲜、安全上下文没有被旧基站滥用。实际系统可以通过重新 AKA、安全上下文转移或派生新密钥来完成，不一定每次都跑完整认证；但安全目标都是防伪基站、防重放、防旧密钥长期复用。

预测 2: LTE 密钥管理、前向/后向安全 (15 分)

可能题目：说明 LTE 为什么要区分 NAS 安全和 AS 安全。LTE 密钥管理能否实现前向安全和后向安全？

考试答案：LTE 中 eNB 功能增强、数量多、部署分散，可能处于不完全可信区域，因此它是新的风险点。NAS 安全保护 UE 与 MME 之间的核心网控制信令；AS 安全保护 UE 与 eNB 之间的 RRC 信令和用户面。分层的意义是密钥隔离：eNB 只掌握接入层相关密钥，不掌握 NAS 层密钥，即使某个 eNB 出问题，也不应直接破坏核心网控制面安全。

LTE 密钥层次可写为

$$K \rightarrow CK/IK \rightarrow K_{ASME} \rightarrow K_{NAS}, K_{eNB} \rightarrow K_{RRC}, K_{UP}.$$

后向安全指目标 eNB 不能解密源 eNB 下过去的通信；前向安全指源 eNB 不能知道目标 eNB 未来通信所用密钥。LTE 通过 KDF、 K_{eNB} 派生、NH/NCC 链式更新等机制增强这两类安全。

考试中不要写“绝对完全实现”。稳妥结论是：LTE 的分层密钥和 NH/NCC 可以较好增强切换中的前向/后向安全，但具体是否完全满足取决于切换方式、密钥派生方式和安全上下文处理。如果直接转发旧密钥，就会破坏安全；如果从上层密钥或 NH 派生新密钥，则风险明显降低。

预测 3：5G 匿名新方法 SUPI/SUCI (15 分)

可能题目：5G 采用什么新方法实现用户身份匿名？分析其优点和不足。

考试答案：5G 的新方法是用 SUCI 隐藏 SUPI。SUPI 是用户永久身份，类似以前的 IMSI；SUCI 是使用归属网公钥对 SUPI 进行随机化加密后得到的隐藏身份。UE 在空口发送 SUCI，服务网不能直接知道真实永久身份，归属网中的 SDF 用私钥恢复 SUPI。随机化很关键，因为如果同一个 SUPI 每次生成相同 SUCI，攻击者仍可链接同一用户。

优点：第一，永久身份不再像 IMSI 那样容易在空口明文暴露；第二，可减少 IMSI catcher/伪基站诱导身份泄露；第三，随机化加密降低长期跟踪和可链接性；第四，结合 5G-AKA、 K_{AUSF} 、 K_{SEAF} 、 K_{AMF} 等分层密钥，可把身份保护、认证和密钥协商结合起来。

不足：第一，SUCI 主要保护永久身份，不等于完全匿名，位置、业务模式、寻呼、错误消息仍可能泄露信息；第二，如果归属网公钥配置或保护不当，身份隐藏会受影响；第三，认证失败原因、SQN 重同步等细节若处理不好，可能造成可链接性；第四，服务网和归属网仍需要合法识别用户，所以这是一种“对空口攻击者隐藏身份”，不是对所有网络实体匿名。

预测 4：LTE 用户面完整性缺口与 5G 改进

可能题目：为什么说 LTE 用户面完整性保护是安全缺口？5G 如何改进？结合“只加密不完整性”分析。

简要答案：LTE 中 NAS 和 RRC 信令完整性通常强制保护，但用户面完整性通常可选或未开启。加密只能防窃听，不能防篡改。攻击者即使看不懂密文，也可能修改、插入、删除或重放用户面数据，造成 DNS 欺骗、数据注入、重定向等风险。5G 支持用户面完整性保护，可按业务和承载配置，高安全场景如工业控制、车联网、电网、医疗应开启。改进方案是启用 UP 完整性或认证加密，将方向、承载、COUNT/序列号、Nonce、密文纳入 MAC，接收端检查重放窗口。

预测 5：2G 到 5G 安全演进综合比较

可能题目：比较 GSM、WCDMA、LTE、5G 在认证、完整性、身份隐私和密钥管理上的演进。

简要答案：GSM 是单向认证，使用 IMSI/TMSI，生成 K_c 做空口加密，但无完整性。WCDMA 使用 AKA 双向认证，认证向量含 RAND、XRES、CK、IK、AUTN，增加信令完整性，CK/IK 分离。LTE 使用 EPS AKA，NAS/AS 分层，使用 GUTI/S-TMSI 隐藏身份，密钥从 K_{ASME} 派生到 NAS、eNB、RRC、UP，支持 NH/NCC 切换密钥。5G 使用 SUCI 隐藏 SUPI，5G-AKA/EAP 增强认证，密钥层次含 K_{AUSF} 、 K_{SEAF} 、 K_{AMF} 、 K_{gNB} ，增强用户面完整性、切片、SEPP 和 SBA 安全。趋势是：单向到双向，空口加密到多层完整性，临时身份到公钥隐藏身份，简单密钥到分层密钥。

预测 6：只加密不完整性/不防重放的综合分析题（15–20 分）

可能题目：某方案只对无线用户面数据加密，不做完整性校验，也不检查序列号。请分析缺陷并给出改进建议。

考试答案：该方案只提供机密性，不提供完整性、新鲜性和可靠认证。无线信道开放，攻击者不只能窃听，还能主动修改、插入、删除和重放报文。只加密可以让攻击者看不懂明文，但不能阻止他改密文；接收端没有 MAC 或认证标签，就无法判断数据是否被篡改。不检查序列号、COUNT 或时间新鲜性，旧报文可能被再次发送并被接收端接受。若方向、承载、算法标识、身份等没有纳入认证，还可能出现跨方向、跨承载或降级攻击。

改进建议：第一，使用 AES-GCM、AES-CCM 等认证加密，或采用“先加密后 MAC”；第二，认证标签应覆盖身份、方向、承载、算法标识、序列号/COUNT、IV/Nonce 和密文；第三，接收端维护重放窗口，拒绝重复、乱序过大和过期报文；第四，用 KDF 分离加密密钥和完整性密钥，不要一钥多用；第五，在切换、计数器接近上限或认证周期到期时更新密钥。总结句可以写：安全通信不能只看“是否加密”，还要同时满足完整性、认证和新鲜性。

同类 20 分变体：若题目给 AES-CBC，写“IV||C 级联传输，通信密钥提前通过安全信道交换”，不要只说 CBC 是错的。应分层评价：密钥通过安全信道交换可以解决一部分密钥分发和身份认证问题；CBC 使用随机不可预测 IV 时能提供基本机密性；但 IV 本身不能当完整性保护，CBC 也不是认证加密。攻击者可以篡改 IV 或密文块造成明文可控翻转，接收方若没有 MAC 可能发现不了；如果 IV 重复或可预测，会削弱安全；如果没有序列号，还会被重放。建议改为 AES-GCM/CCM，或 CBC 加 HMAC，并把通信双方身份、算法、序列号、IV 和密文一起认证。

预测 7：5G 切片、SEPP、SBA

可能题目：说明 5G 网络切片为什么需要二次认证，SEPP 和 SBA 安全分别解决什么问题。

简要答案：主认证只能证明 UE 是合法移动用户，不能证明其有权进入某个行业切片。切片二次认证用于验证用户是否有资格访问智能电网、车联网、工业控制等专用切片，实现切片级访问控制和最小权限。SEPP 保护运营商之间的漫游边界，提供跨 PLMN 信令过滤、完整性/机密性保护和拓扑隐藏。SBA 是服务化核心网，网元像 API 一样互相调用，需 TLS、OAuth、访问控制、服务发现安全和日志审计，防止接口滥用和越权访问。

预测 8：综合设计题，按 20 分题准备

可能题目：某无线接入系统中，终端需要通过开放无线信道接入网络。系统要求保护用户永久身份，完成终端与网络的双向认证，协商会话密钥，并对后续信令和用户数据提供安全保护。请设计一个安全接入方案，并说明各步骤解决的安全问题。

答题思路：这种题不要只写一个算法，要按“身份保护 → 双向认证 → 密钥协商 → 安全上下文建立 → 数据保护 → 切换/更新”来写。画不出复杂图也没关系，写清每一步和安全目标就有分。

参考答案：

1. **身份保护阶段**：终端不直接发送永久身份 IMSI/SUPI，而是使用临时身份 TMSI/GUTI；若没有可用临时身份，则使用归属网公钥对永久身份随机化加密，形成类似 SUCI 的隐藏身份。这样可以防止攻击者在空口捕获永久身份并长期跟踪用户。
2. **认证请求阶段**：终端向网络发送接入请求，消息中包含隐藏身份、终端支持的安全算法、随机数 R_{UE} 和必要的网络标识。算法列表和随机数后续要纳入完整性保护，防止降级攻击。
3. **认证向量生成阶段**：归属网根据用户长期密钥 K 生成认证向量，如 $RAND$ 、 $XRES$ 、 $AUTN$ 、加密密钥材料和完整性密钥材料。 $RAND$ 保证挑战新鲜， $AUTN$ 让终端验证网络， $XRES$ 用于网络验证终端响应。
4. **双向认证阶段**：网络向终端发送 $RAND$ 和 $AUTN$ 。终端用 USIM 中长期密钥验证 $AUTN$ 中的 MAC 和 SQN：MAC 正确说明网络合法，SQN 合理说明不是旧消息重放。终端再计算 RES 返回网络，网络比较 RES 和 XRES，完成对终端的认证。这样同时防伪基站、防非法终端、防重放。
5. **密钥派生阶段**：认证成功后，双方使用 KDF 从上层密钥派生不同用途的会话密钥，例如信令加密密钥、信令完整性密钥、用户面加密密钥、用户面完整性密钥，并区分方向、承载和算法。这样避免一钥多用，减少单个密钥泄露后的影响。
6. **安全模式建立阶段**：网络发送安全模式命令，明确选择的加密算法、完整性算法、承载和计数器初值。该命令必须进行完整性保护，终端确认后才开启安全上下文，防止攻击者篡改算法协商或强迫使用弱算法。
7. **信令和用户数据保护阶段**：后续控制信令必须同时加密和完整性保护；用户面数据至少应加密，高安全业务应开启完整性保护。每个报文使用 COUNT/序列号、方向、承载号和 Nonce，并将这些字段纳入 MAC 或认证加密标签，接收端检查重放窗口，拒绝重复和过期报文。
8. **切换和密钥更新阶段**：终端移动到新基站时，不直接复用旧基站密钥，而是用 KDF、目标小区参数和类似 NH/NCC 的链式密钥派生新基站密钥，保证目标基站不能解密过去通信，源基站不能知道未来通信。密钥还应在计数器接近上限、重认证或安全策略要求时更新。
9. **异常与隐私保护**：错误消息尽量统一，避免通过 MAC Failure/Sync Failure 等差异泄露用户是否存在；临时身份定期更新，寻呼和重同步流程也要避免暴露永久身份。

最后总结句：该方案把身份隐私、双向认证、密钥协商、完整性保护、防重放和切换密钥更新结合起来，形成完整的无线接入安全机制，比“只加密数据”或“只认证用户”的方案更安全。

预测 9：WEP 功能原理和安全缺陷（10 分）

可能题目：说明 WEP 的功能原理，并分析它的安全性缺陷。

考试答案：WEP 是早期 WLAN 安全机制，目标是给无线局域网提供类似有线网络的保密性。它使用 RC4 流密码，把共享密钥和 24 bit IV 拼接或混合后生成密钥流，再与明文异或得到密文；同时用 CRC-32 生成 ICV，接收端用它检查传输错误。WEP 还可使用共享密钥认证。

缺陷要分点写：第一，24 bit IV 太短，实际网络中很容易重复，流密码一旦密钥流复用，就可能泄露明文关系；第二，长期静态共享密钥难以管理，一个人泄露会影响整个网络；第三，CRC-32 不是带密钥的 MAC，只能检查随机错误，不能抵抗恶意篡改；第四，共享密钥认证会暴露明文和密文关系，反而帮助攻击者；第五，RC4 与 WEP 的密钥使用方式存在弱点。改进方向是使用 WPA2/802.11i：通过 802.1X/EAP 或 PSK 完成认证，四次握手用 ANonce/SNonce 派生 PTK/GTK，AES-CCMP 同时提供加密、完整性和防重放。

预测 10：GSM 缺陷与伪基站

可能题目：说明 GSM 的认证和加密过程，分析为什么它容易受到伪基站和 IMSI catcher 攻击。

简要答案：GSM 中 SIM 和 AuC 共享 K_i ，网络发 RAND，SIM 用 A3 算 SRES，用 A8 算 K_c ，网络比较响应后认证用户，A5 用 K_c 和帧号 Fn 进行空口加密。缺陷是单向认证，手机不能认证网络，因此伪基站可冒充合法网络；无完整性保护，信令可被篡改；首次接入或 TMSI 失效时可能明文发送 IMSI，因此 IMSI catcher 可诱导 UE 暴露永久身份；早期 A5/COMP128 算法也较弱。

预测 11：TETRA 空口加密与端到端加密同步区别（10 分）

可能题目：TETRA 空口加密和端到端加密的密钥流同步有什么区别？

考试答案：TETRA 的空口加密保护 MS 到基站/SwMI 的无线链路，加密终止在网络侧；端到端加密保护最终终端之间的业务内容，中间网络只转发密文，不能看到业务明文。两者都要保证发送端和接收端使用同一密钥流位置，否则解密会失败，但同步位置和同步对象不同。

空口加密的同步主要发生在无线链路两端，即 MS 与基站/SwMI 之间。它通常依赖帧号、时隙、IV 或链路同步信息，让无线链路两端的 KSG 生成相同密钥流。因为网络参与空口加密，所以切换、重选、链路建立时需要由网络帮助维护同步。端到端加密的同步发生在两个最终终端之间，中间 SwMI 不应掌握业务明文和端到端密钥，因此需要在业务流中携带同步帧、同步值 SV、Key ID 等信息，让接收终端知道使用哪把端到端密钥以及从哪个同步值开始生成密钥流。总结：空口同步是“终端-网络”的链路同步，端到端同步是“终端-终端”的业务密钥流同步。

1 第一讲：课程概述与无线安全发展

人话理解：

这一章是总论。它告诉你：为什么无线通信比有线通信更需要安全，以及无线安全是怎么从 1G 慢慢发展到 5G/未来网络的。

无线通信的根本问题是：**无线电波在空气中传播，空气不可信。**攻击者不一定要接网线，只要在附近就可能监听、干扰、伪造信号。手机还会移动，基站数量多，终端能力有限，所以安全设计比普通有线网络更麻烦。

1.1 本章可能考法

1. 论述无线通信为什么需要安全机制。

简答：无线信道开放，攻击者可在附近监听、干扰、伪造信号；终端移动、基站分散、核心网复杂，所以必须做认证、加密、完整性、防重放和身份隐私保护。

2. 分析无线通信面临的主要威胁。

简答：主要威胁包括空口窃听、消息篡改、重放、伪基站、中间人、干扰、拒绝服务、IMSI/SUPI 捕获、位置跟踪、核心网信令滥用。

3. 说明 1G 到 5G 安全机制的演进趋势。

简答：1G 基本无安全；2G 有单向认证和空口加密；3G 增加双向 AKA 和信令完整性；4G 做 NAS/AS 分层与切换密钥；5G 增强 SUCI、用户面完整性、切片、漫游和 SBA 安全。

4. 结合移动通信案例，分析身份隐私和位置跟踪风险。

简答：永久身份明文传输会被监听和关联，攻击者可通过伪基站或信令滥用追踪用户位置。改进是使用 TMSI/GUTI/SUCI、加密身份、定期更新临时身份并保护寻呼和错误消息。

大题答题框架：

答这章大题可以按四段写：

1. 先说无线信道开放、终端移动、基站分散、核心网复杂。
2. 再说攻击：窃听、篡改、伪基站、重放、干扰、位置跟踪。
3. 再说安全目标：认证、机密性、完整性、新鲜性、匿名性、可用性。
4. 最后说发展趋势：从无到有、从单向到双向、从只加密到完整保护、从空口到网络域/切片/SBA。

1.2 安全目标

目标	简单解释
机密性	别人听到了也看不懂，通常靠加密。
完整性	别人改了消息能发现，通常靠 MAC、完整性算法、认证标签。
认证性	确认对方是真的，不是假用户、假基站、假网络。
新鲜性	确认这不是旧消息重放，靠随机数、序列号、SQN、COUNT。
身份隐私	不轻易暴露 IMSI/SUPI，不让攻击者长期跟踪用户。
可用性	防止干扰、拒绝服务、恶意去认证等让系统不可用。

1.3 无线安全发展历史

阶段	安全特点和缺陷
1G	基本没有安全机制，模拟通信容易被监听和复制。
2G/GSM	有用户鉴权、空口加密、TMSI 临时身份；但只有网络认证用户，缺少用户对网络认证，缺少完整性保护。
3G/WCDMA	引入 AKA 双向认证，CK/IK 分离，增加信令完整性，修补 GSM 的假基站和完整性问题。
4G/LTE	NAS/AS 分层安全，密钥层次复杂，支持快速切换密钥管理；但用户面完整性通常不强制。
5G	使用 SUCI 隐藏 SUPI，增强 5G-AKA、用户面完整性、切片安全、漫游安全和 SBA 安全。
未来/6G	面向空天地一体化、海量物联网、边缘云、AI、抗量子和网络韧性。

考场答题角度：

无线通信由于信道开放、用户移动、终端分散、基站部署环境复杂，容易遭受空口窃听、伪基站、中间人、重放、干扰、身份跟踪和拒绝服务攻击。因此无线通信系统必须提供身份认证、密钥协商、空口加密、完整性保护、防重放和匿名性保护。从发展趋势看，移动通信安全经历了从无安全机制到 2G 单向认证和空口加密，再到 3G 双向 AKA 和信令完整性，4G 的 NAS/AS 分层与切换密钥管理，以及 5G 的 SUCI 身份隐藏、用户面完整性、切片与服务化核心网安全。

不会写也要写的得分词：

无线信道开放；空口窃听；伪基站；身份隐私；认证；加密；完整性；防重放；移动切换；从 2G 到 5G 安全增强。

2 第二讲：密码学基础与认证理论

人话理解：

这一章是工具箱。后面所有系统都在用这些工具：加密、MAC、随机数、序列号、密钥协商、数字签名。考试不会让你做很难的数学推导，但会让你分析“这个方案缺了什么”。

2.1 本章可能考法

1. 说明加密、完整性、认证、防重放分别解决什么问题。

简答：加密解决机密性，MAC/认证标签解决完整性，认证解决“对方是谁”，随机数、序列号、计数器解决新鲜性和防重放。

2. 分析“只加密不做完整性”的缺陷。

简答：只加密只能防偷看，不能防篡改、插入、删除、重放和伪造。攻击者可改密文或 IV，接收方不一定发现。应加 MAC 或使用 CCM/GCM 等认证加密。

3. 比较对称密码、公钥密码、分组密码、流密码。

简答：对称密码速度快但密钥分发难；公钥密码便于认证和密钥交换但开销大；分组密码按块处理，如 AES；流密码生成密钥流，重点是密钥流不能重复。

4. 说明 ECB/CBC/CTR/CCM/GCM 等模式特点。

简答：ECB 泄露相同明文块；CBC 需 IV，安全性好于 ECB；CTR 高效并行但 Nonce 不能重复；CCM/GCM 同时提供加密和完整性。

5. 给一个协议，让你从机密性、完整性、认证、新鲜性分析缺陷。

简答：先检查有没有加密，再检查 MAC/完整性，再看是否双向认证，再看随机数/序列号防重放，最后看密钥是否分离、是否更新、身份是否暴露。

2.2 基本概念

概念	考试解释
加密	保护机密性，让攻击者听到也看不懂。但加密本身不能保证消息没有被改。
MAC	带密钥的完整性校验，能发现篡改，也能证明消息来自知道密钥的一方。
数字签名	私钥签名、公钥验证，能认证来源并提供抗抵赖，但开销较大。
随机数/Nonce	保证每次协议运行不同，防重放。
序列号/计数器	按顺序递增，用于检查旧消息、重复消息和乱序消息。
密钥派生 KDF	从一个上层密钥派生多个下层密钥，实现不同用途不同密钥。

2.3 密码体制分类

- **对称密码**：加密和解密用同一把密钥，速度快，适合大量数据加密。缺点是密钥分发困难。
- **公钥密码**：公钥公开，私钥保密，适合密钥交换、身份认证和数字签名。缺点是计算开销大。
- **分组密码**：把明文分成固定大小的数据块处理，比如 AES。
- **流密码**：生成密钥流，与明文异或，比如 RC4、A5。重点风险是密钥流不能重复。

2.4 密码分析攻击类型

攻击类型	人话解释
唯密文攻击	攻击者只有密文，能力最弱。

已知明文攻击	攻击者知道一些明文和对应密文。
选择明文攻击	攻击者能让加密机加密自己选择的明文。
选择密文攻击	攻击者能让解密机解密自己选择的密文，能力更强。

2.5 分组密码模式

模式	考试重点
ECB	每块独立加密，相同明文块产生相同密文块，泄露模式，不推荐。
CBC	每块与前一块密文相关，需要 IV，安全性好于 ECB，但要配完整性保护。
CFB/OFB	把分组密码变成类似流密码使用，要求同步，IV/初始状态很重要。
CTR	用计数器生成密钥流，可并行，效率高；Nonce/计数器绝不能重复。
CCM	CTR 加密加 CBC-MAC，既加密又认证，WPA2 的 CCMP 使用类似思想。
GCM	高效认证加密模式，同时提供机密性和完整性，现代系统常用。

2.6 只加密不安全

这是最重要考点。加密只防偷看，不防乱改。攻击者不懂密文，也可能修改、删除、插入、重放密文。如果没有 MAC 或认证标签，接收方可能不知道。

考场答题角度：

加密主要保证机密性，不能自动保证完整性、认证性和新鲜性。攻击者可以在不知道明文的情况下修改密文、替换 IV、重排数据块、插入旧消息或重放历史报文。因此安全协议应采用加密与完整性保护结合的机制，如加密后 MAC 或认证加密 CCM/GCM，并将身份、算法标识、方向、承载号、序列号、IV/Nonce 和密文纳入认证范围，同时使用随机数、序列号或计数器防止重放。

不会写也要写的得分词：

加密防偷看；MAC 防篡改；随机数防重放；认证防冒充；KDF 做密钥分离；Nonce 不能重复；只加密不够。

3 第三讲：无线通信威胁与安全体系

人话理解：

这一章教你怎么分析系统。老师如果给你一个新方案，不一定要你背某个协议，而是看你能不能从威胁、安全需求、安全机制三个层次分析。

3.1 本章可能考法

- 1. 列出无线通信系统的主要安全威胁。
简答：主要威胁有窃听、篡改、插入、删除、重放、伪造、干扰、拒绝服务、冒充用户或基站、身份泄露、位置跟踪、核心网攻击。
- 2. 按位置或对象对威胁分类。
简答：按位置可分无线链路、服务网络、终端、核心网威胁；按对象可分对信息、对用户、对通信系统的威胁。
- 3. 说明无线安全体系中的安全服务、安全需求、安全域。
简答：安全服务包括认证、访问控制、机密性、完整性、抗抵赖、密钥管理、可用性；安全域包括接入域、网络域、用户域、应用域。
- 4. 判断接入认证和 PIN 码认证是否属于同一安全域。
简答：不完全属于同一安全域。接入认证主要属于接入域，解决 UE 能否接入移动网络以及网络是否可信；PIN 码认证主要属于用户域，解决用户能否使用 SIM/USIM 或终端。二者都属于认证，但保护对象和安全边界不同。
- 5. 分析接入域、网络域、用户域分别面临什么威胁。
简答：接入域面临空口窃听、伪基站、非法接入；网络域面临核心网信令篡改、网元伪造；用户域面临 SIM/USIM 盗用、终端被攻破；应用域面临业务数据泄露和应用层攻击。

3.2 威胁分类

分类方式	内容
按攻击位置	无线链路威胁、服务网络威胁、终端威胁、核心网威胁。
按攻击对象	对传递信息的威胁、对用户的威胁、对通信系统的威胁。
按攻击方式	被动窃听、主动篡改、插入、删除、重放、伪造、干扰、拒绝服务。

3.3 三类主要威胁

- 1. 对传递信息的威胁：窃听、修改、插入、删除、重放、抵赖。
- 2. 对用户的威胁：身份冒充、IMSI/SUPI 暴露、位置跟踪、流量分析。
- 3. 对系统的威胁：干扰、拒绝服务、破坏基站、攻击数据库、越权访问核心网资源。

3.4 安全服务、需求、域

维度	内容
----	----

安全服务	认证、访问控制、机密性、完整性、抗抵赖、密钥管理、可用性。
安全需求层次	管理层制定策略，用户层提供端到端安全，控制层实现鉴权和用户管理，链路层保护无线传输。
安全域	接入域、网络域、用户域、应用域。

3.5 安全域

- **接入域**：UE 接入网络时的安全，重点是认证、密钥协商、空口加密、完整性和身份保护。
- **网络域**：核心网节点之间安全交换信令，重点是网元认证、机密性、完整性和攻击监测。
- **用户域**：用户、USIM/SIM、终端之间的本地安全，比如 PIN、USIM 与终端认证。
- **应用域**：应用服务自己的安全，比如 HTTPS、支付、聊天软件端到端加密。

考场答题角度：

如果题目问“接入认证和 PIN 码认证是不是同一安全域”，建议答：它们都属于广义认证机制，但不属于完全相同的安全域。接入认证发生在 UE 接入移动网络时，重点是网络认证用户、用户认证网络、协商会话密钥，属于接入域；PIN 码认证发生在用户使用 SIM/USIM 或终端时，重点是防止他人拿到卡或手机后直接使用，属于用户域。二者的共同点是都在确认身份，区别是认证对象、保护边界和攻击场景不同。

大题答题框架：

如果问安全体系，按“威胁 → 需求 → 机制 → 评估”写：

1. 威胁分析：列出攻击者可能做什么。
2. 风险分析：攻击难度和后果。
3. 确定需求：认证、机密性、完整性、隐私、可用性。
4. 设计机制：AKA、加密、MAC、临时身份、密钥派生。
5. 安全分析：看是否有漏洞，是否能扩展应对新攻击。

考场答题角度：

无线通信安全体系应以威胁分析为基础，针对无线链路开放、终端移动、核心网复杂等特点，确定认证、机密性、完整性、新鲜性、隐私保护和可用性等安全需求。体系上可划分为接入域、网络域、用户域和应用域。接入域主要防止空口窃听、伪基站和非法接入；网络域保护核心网节点间信令；用户域保护 USIM、终端和用户本地认证；应用域保护具体业务。安全设计应从威胁出发，选择认证、加密、完整性校验、密钥管理和临时身份等机制，并持续评估漏洞。

不会写也要写的得分词：

威胁分析；风险分析；安全需求；安全机制；安全评估；接入域最重要；无线链路开放；服务网络威胁；终端威胁。

4 第四讲：WLAN 安全

人话理解：

WLAN 就是 WiFi。这章最常考的是：WEP 为什么不安全，WPA/WPA2/WPA3 怎么改进。

4.1 本章可能考法

1. 分析 WEP 的工作机制和缺陷。

简答：WEP 用 RC4、共享密钥和 24 bit IV 生成密钥流，用 CRC-32 做 ICV。缺陷是 IV 短、密钥流易重复、CRC 不是 MAC、静态密钥难管理、认证过程弱。

2. 比较 WEP、WPA、WPA2、WPA3。

简答：WEP 是早期弱方案；WPA/TKIP 是过渡方案，仍用 RC4 但增强密钥混合和 MIC；WPA2 用 802.1X/PSK、四次握手和 AES-CCMP；WPA3 用 SAE 增强口令认证。

3. 说明 802.1X/EAP、四次握手、动态密钥管理。

简答：802.1X/EAP 负责接入认证；四次握手用 ANonce/SNonce 确认双方有 PMK，并派生 PTK/GTK；动态密钥管理避免长期静态共享密钥。

4. 分析伪 AP、去认证攻击、弱口令攻击。

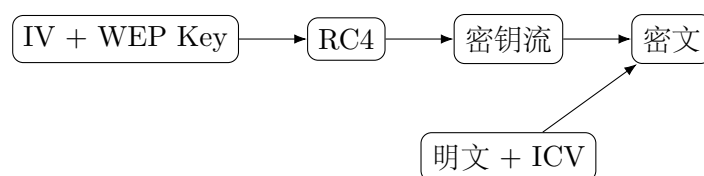
简答：伪 AP 通过假热点骗用户接入，应验证证书和使用企业认证；去认证攻击可用管理帧保护缓解；弱口令攻击需强密码或 WPA3-SAE。

4.2 WLAN 安全目标

WLAN 的目标包括可认证性、机密性、完整性、访问控制和可用性。由于 AP 和终端通过无线信道通信，所以既要保护数据帧，也要保护接入认证和密钥协商。

4.3 WEP 机制

WEP 使用 RC4 流密码。它把共享密钥和 24 bit IV 合在一起生成密钥流，再与明文异或得到密文，同时用 CRC-32 生成 ICV 做完整性检查。



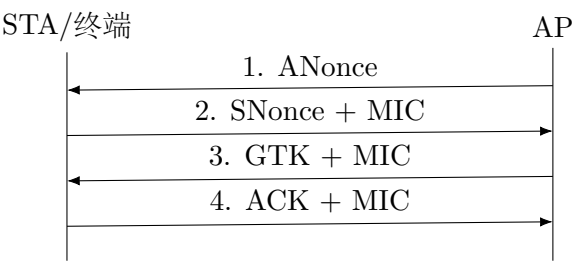
4.4 WEP 缺陷

1. IV 只有 24 bit，容易重复。
2. 流密码密钥流重复会导致严重泄露。

- 3. CRC-32 不是安全 MAC，只能检查偶然错误，不能防恶意篡改。
- 4. 静态共享密钥难管理，泄露后影响所有用户。
- 5. 共享密钥认证会暴露明文/密文关系。
- 6. 缺乏真正的动态密钥更新和强防重放机制。

4.5 802.1X/EAP 与四次握手

802.1X/EAP 负责接入认证，四次握手负责确认双方都有 PMK，并派生 PTK/GTK。



ANonce、SNonce 提供新鲜性；MIC 保护握手完整性；PTK 保护单播，GTK 保护组播/广播。

4.6 WEP/WPA/WPA2/WPA3 对比

协议	答题重点
WEP	静态密钥，RC4，24 bit IV，CRC-32，安全性弱。
WPA/TKIP	过渡方案，仍用 RC4，但加入 TKIP、密钥混合、MIC、防重放。
WPA2/802.11i	正式增强，802.1X/PSK、四次握手、AES-CCMP，提供机密性和完整性。
WPA3	使用 SAE，即基于口令的认证密钥交换，增强抗离线字典攻击能力。

4.7 常见攻击与改进

- 伪 AP：加强服务器证书验证、企业级 802.1X。
- 去认证攻击：管理帧保护 PMF。
- 弱口令：使用强密码或 WPA3-SAE。
- 重放攻击：使用计数器、序列号和 MIC。
- 路由器固件漏洞：安全启动、及时升级、供应链安全。

考场答题角度：

WEP 使用 RC4 流密码、共享密钥和 24 bit IV 生成密钥流，对数据进行异或加密，并使用 CRC-32 作为完整性校验。但 IV 过短易重复，流密码密钥流复用会泄露信息；CRC-32 不是带密钥的 MAC，无法抵抗恶意篡改；静态共享密钥难以管理，认证过程也可能泄露明密文关系。因此 WEP 不能提供可靠安全。WPA/TKIP 作为过渡方案改进了密钥混合和完整性；WPA2/802.11i 通过 802.1X/EAP 或 PSK 认证、四次握手动态派生 PTK/GTK，并使用 AES-CCMP 同时提供机密性和完整性；WPA3 进一步引入 SAE，增强口令认证安全。

不会写也要写的得分词：

WEP；RC4；24 bit IV；CRC 不是 MAC；静态密钥；802.1X；EAP；四次握手；ANonce/SNonce；PTK/GTK；AES-CCMP；WPA3-SAE。

5 第五讲：GSM 安全

人话理解：

GSM 是 2G。它的安全可以概括为：网络认证用户，空口加密，使用 TMSI 做一定匿名。但它最大缺点是单向认证和无完整性保护。

5.1 本章可能考法

1. 说明 GSM 鉴权和加密过程。

简答：SIM 和 AuC 共享 K_i ，网络发 RAND，SIM 用 A3 算 SRES，网络比较响应完成鉴权；双方用 A8 生成 K_c ，A5 用 K_c 和帧号 Fn 加密空口。

2. 分析 GSM 的安全目标与安全机制。

简答：GSM 目标是用户鉴权、空口机密性、一定身份匿名和 SIM 本地安全；机制包括 PIN/PUK、挑战应答鉴权、A5 空口加密、TMSI 临时身份。

3. 分析 GSM 缺陷：单向认证、无完整性、IMSI 暴露、算法弱。

简答：GSM 是单向认证，手机不认证网络，容易被伪基站骗；无完整性保护，信令可被篡改；IMSI 某些场景明文；早期 A5/COMP128 算法弱。

4. 解释 IMSI/TMSI、 K_i/K_c 、A3/A8/A5。

简答：IMSI 是永久身份，TMSI 是临时身份； K_i 是长期密钥， K_c 是会话加密密钥；A3 算 SRES，A8 算 K_c ，A5 做空口加密。

5.2 GSM 网络实体

- MS：移动台，手机和 SIM。
- BTS/BSS：基站/基站子系统。
- MSC：移动交换中心。
- HLR：归属位置寄存器，保存用户永久资料。

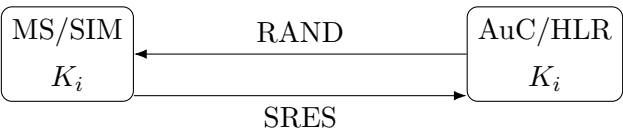
- VLR：拜访位置寄存器，保存访问区域临时资料。
- AuC：认证中心，保存 K_i ，生成认证三元组。
- EIR：设备识别寄存器，管理设备合法性。

5.3 GSM 安全机制

机制	作用
PIN/PUK	SIM 本地安全，防止别人盗用 SIM。
用户鉴权	网络通过挑战-应答认证用户。
空口加密	使用 K_c 和 A5 保护空中接口。
匿名	尽量使用 TMSI，而不是 IMSI。

5.4 鉴权和密钥生成

SIM 和 AuC 共享长期密钥 K_i 。网络发 RAND，SIM 用 A3 算 SRES，用 A8 算 K_c 。



- A3: $SRES = A3(K_i, RAND)$ ，用于认证。
- A8: $K_c = A8(K_i, RAND)$ ，生成会话加密密钥。
- A5：使用 K_c 和帧号 F_n 生成密钥流，保护空口。

K_i 不在空口传输，A3/A8 在 SIM 和 AuC 中实现。很多 GSM 网络使用 COMP128 作为 A3/A8 实现。

5.5 匿名机制

IMSI 是永久身份，TMSI 是临时身份。GSM 尽量用 TMSI 在空口识别用户，减少 IMSI 暴露。但首次注册、TMSI 失效或网络无法从 TMSI 找到 IMSI 时，手机可能明文发送 IMSI。这就是 IMSI catcher 能利用的点。

5.6 GSM 缺陷

1. 单向认证：网络认证用户，用户不认证网络，容易被伪基站骗。
2. 无完整性保护：信令被改可能发现不了。
3. IMSI 仍可能明文暴露。
4. A5/1、A5/2、COMP128 等早期算法存在弱点。

5. 只保护空口，不提供端到端加密。
6. 固定网/核心网内部早期缺少足够认证和加密。

考场答题角度：

GSM 中 SIM 与 AuC 共享长期密钥 K_i 。网络发送随机数 RAND，SIM 使用 A3 算法计算 SRES，网络比较 SRES 与期望响应完成对用户的鉴权；同时 SIM 和网络通过 A8 算法生成会话密钥 K_c ，再由 A5 算法结合帧号 Fn 生成密钥流，对空中接口进行加密。GSM 还使用 TMSI 代替 IMSI，以减少永久身份暴露。但 GSM 只提供网络对用户的单向认证，手机不能认证网络，容易遭受伪基站攻击；系统缺少完整性保护；IMSI 在某些场景仍会明文发送；部分早期算法强度不足。因此 GSM 只能提供有限的空口保密，不能提供完整的无线通信安全。

不会写也要写的得分词：

K_i ；RAND；SRES；A3；A8； K_c ；A5；Fn；IMSI；TMSI；单向认证；无完整性；伪基站。

6 第六讲：TETRA 安全

人话理解：

TETRA 是专业数字集群通信，常用于公安、应急、专网。它比普通公网更强调调度、组呼、专用业务安全。

6.1 本章可能考法

1. 说明 TETRA 安全需求和威胁。

简答：TETRA 用于专网、应急、公安等场景，需防监听、假终端、假基站、控制信息篡改、组呼泄露和业务滥用。

2. 比较空口加密、传输加密、端到端加密。

简答：空口加密保护终端到基站/SwMI 的无线链路；传输加密保护有线或微波传输链路；端到端加密保护终端到终端业务内容，中间网络也看不懂。

3. 说明 TETRA 双向鉴权。

简答：双向鉴权基于 MS 与 SwMI 共享主密钥 K，通过随机数挑战证明双方知道 K，但不在空口传输 K，可防虚假终端和虚假基站。

4. 分析 TETRA 鉴权协议优点和不足。

简答：优点是双向鉴权、多随机数防重放；不足是主密钥更新机制不足、缺少显式密钥确认、理论中间人风险和抗抵赖能力不足。

5. 解释 Class 1/2/3、SCK/DCK/CCK。

简答：Class 1 不使用空口加密；Class 2 使用 SCK 静态密钥；Class 3 使用 DCK/CCK 等动态或通用密钥，安全更强。

6.2 TETRA 安全需求

TETRA 面向专业集群用户，需要比普通公网更高安全性：

- 调度台、组成员、终端身份认证。
- 防止个呼和组呼被监听。
- 保护控制信息和业务信息完整性。
- 支持空口加密、传输加密、端到端加密。

6.3 识别码

- ITSI：个人用户完整身份。
- ISSI：个人用户短身份。
- GTSI：群组完整身份。
- GSSI：群组短身份。

6.4 安全等级

等级	考试解释
Class 1	不使用空口加密，可使用鉴权，安全较弱。
Class 2	必须使用 SCK 静态密钥加密，适合较简单场景。
Class 3	必须使用鉴权，并使用 DCK/CCK 等动态或通用密钥，安全更强。

6.5 鉴权

TETRA 支持 MS 对 SwMI 鉴权、SwMI 对 MS 鉴权，以及双向鉴权。其基本思想是双方共享主密钥 K，通过随机数挑战证明自己知道 K，但不把 K 传到空口上。

6.6 三种加密

加密类型	保护范围
空中接口加密	保护 MS 到基站/SwMI 的无线链路，防止空口监听和控制信息被操纵。
传输加密	保护有线或微波传输链路，防止传输网络被监听。
端到端加密	保护最终终端之间的业务内容，即使中间网络转发也看不懂。

空口加密依赖 IV、帧号、同步信息，使两端密钥流同步。端到端加密常通过同步帧传 SV 和 Key ID，让接收端知道使用哪个密钥和同步值。

6.7 TETRA 鉴权协议分析

- 优点：双向鉴权，能防虚假终端和虚假基站；多个随机数能防重放。
- 不足：主密钥 K 更新机制不足；缺少显式密钥确认；理论上中间人风险仍需分析；无仲裁机构，不能防抵赖。

考场答题角度：

TETRA 是面向专业集群通信的开放标准，安全需求高于普通公网。其安全机制包括鉴权、空中接口加密、传输加密和端到端加密。鉴权基于 MS 与 SwMI 共享的主密钥 K，通过随机数挑战实现双方证明身份，支持双向鉴权，可防虚假终端和虚假基站并抵抗重放。空中接口加密保护无线链路，使用 SCK、DCK、CCK 等密钥和 KSG 密钥流生成器；端到端加密保护终端之间的业务内容，中间网络无法读取明文。TETRA 的不足包括主密钥更新机制不足、缺少显式密钥确认、理论上中间人攻击和抵赖问题仍需考虑。

不会写也要写的得分词：

TETRA；SwMI；双向鉴权；空口加密；传输加密；端到端加密；SCK；DCK；CCK；Class 1/2/3；同步。

7 第七讲：WCDMA 安全

人话理解：

WCDMA 是 3G。它最核心的意义是修补 GSM：把单向认证改成双向认证，把只加密扩展到信令完整性，把密钥从一个 K_c 变成 CK/IK。

7.1 本章可能考法

1. 说明 3G 安全原则和目标。

简答：3G 原则是继承 2G 稳健特征、改进 2G 缺陷、增加新业务安全服务、支持标准化漫游和可扩展安全。

2. 说明 3G 安全体系结构。

简答：体系包括接入安全、网络域安全、用户域安全、应用域安全、安全可见性与可配置性，其中接入域最重要。

3. 重点解释 AKA、AV、AUTN、CK/IK。

简答：AKA 实现双向认证和密钥协商；AV 包含 RAND、XRES、CK、IK、AUTN；AUTN 让 UE 验证网络；CK 用于加密，IK 用于完整性。

4. 比较 WCDMA 与 GSM。

简答：GSM 是单向认证、缺少完整性、主要用 K_c ；WCDMA 是双向 AKA、CK/IK 分离、增加信令完整性和网络域安全。

5. 分析 WCDMA 仍存在的不足。

简答：不足包括 IMSI 仍可能暴露、用户面完整性不足、非端到端安全、SQN 重同步可能导致隐私问题、核心网配置不当仍有风险。

7.2 3G 安全原则

1. 建立在 2G 安全基础上，保留稳健特征。
2. 增强和改进 2G 缺陷。
3. 根据 3G 新业务增加新的安全服务。
4. 安全特征要标准化，支持全球漫游和互通。
5. 安全机制要可扩展，能适应新威胁。

7.3 3G 安全体系结构

- 接入安全：最重要，防无线信道攻击，提供身份机密性、认证、加密、完整性。
- 网络域安全：保护核心网节点间信令，提供网络实体认证、机密性、完整性。
- 用户域安全：用户和 USIM、USIM 和终端之间的安全。
- 应用域安全：用户与运营商或应用提供商之间的应用安全。
- 安全可见性和可配置性：让用户知道安全是否开启，并可配置安全偏好。

7.4 AKA 的目的

AKA = Authentication and Key Agreement，认证与密钥协商。目的：

1. 网络认证用户。
2. 用户认证网络。
3. 生成加密密钥 CK。
4. 生成完整性密钥 IK。
5. 确保 CK/IK 新鲜。

7.5 认证向量 AV

$$AV = (RAND, XRES, CK, IK, AUTN)$$

- RAND：随机挑战。
- XRES：网络期望的响应。

- CK：加密密钥。
- IK：完整性密钥。
- AUTN：认证令牌，UE 用它验证网络合法性。

AUTN 通常包含：

$$AUTN = SQN \oplus AK \parallel AMF \parallel MAC$$

UE 使用共享主密钥 K 重新计算 MAC。如果 MAC 正确，说明认证令牌来自知道 K 的归属网；再检查 SQN 是否在合理范围，防止重放。

7.6 TMSI 再分配

WCDMA 继续使用 TMSI/P-TMSI 保护身份隐私。TMSI 再分配应在加密开启后执行，否则临时身份本身也可能被监听。

7.7 WCDMA 与 GSM 对比

项目	GSM	WCDMA
认证	单向认证，网络认证用户。	双向 AKA，网络和用户互相认证。
密钥	主要是 K_c 。	CK/IK 分离。
完整性	缺少完整性保护。	增加信令完整性保护。
身份隐私	IMSI/TMSI，IMSI 仍可能暴露。	IMSI/TMSI/P-TMSI，仍未彻底解决。
网络域	固定网内部安全不足。	增强网络域安全。

7.8 WCDMA 不足

IMSI 仍可能在特殊场景明文暴露；用户面完整性不足；不是端到端加密；SQN 重同步机制可能带来隐私问题；核心网配置不当仍可能产生安全风险。

考场答题角度：

WCDMA 的核心安全机制是 AKA。归属网 AuC 与 USIM 共享主密钥 K，并生成认证向量 $AV = (RAND, XRES, CK, IK, AUTN)$ 。服务网将 RAND 和 AUTN 发给 UE，UE 通过验证 AUTN 中的 MAC 和 SQN 来认证网络并检查新鲜性，同时计算 RES、CK、IK；网络比较 RES 与 XRES 完成用户认证。相比 GSM，WCDMA 实现双向认证，将加密密钥 CK 与完整性密钥 IK 分离，增加信令完整性保护，并增强网络域安全。但 WCDMA 仍可能存在 IMSI 暴露、用户面完整性不足、非端到端安全和 SQN 隐私问题。

不会写也要写的得分词：

3G 安全原则；接入域；网络域；用户域；AKA；AV；RAND；XRES；AUTN；SQN；MAC；CK；IK；双向认证；信令完整性。

8 第八讲：LTE 安全

人话理解：

LTE 是 4G。它的核心考点是：eNB 不完全可信，所以 LTE 做 NAS/AS 分层安全和分层密钥管理；手机切换频繁，所以需要快速切换密钥机制。

8.1 本章可能考法

1. 说明 LTE 的安全威胁，尤其 eNB 风险。

简答：LTE 最大新增风险来自 eNB：部署分散、不完全可信、可能被物理或网络攻击，掌握接入层密钥，传输链路也可能不安全。

2. 解释 NAS 安全和 AS 安全。

简答：NAS 安全保护 UE 与 MME 之间的核心网控制信令；AS 安全保护 UE 与 eNB 之间的 RRC 信令和用户面，分层可隔离 eNB 风险。

3. 说明 LTE 密钥层次。

简答：密钥从长期密钥经 CK/IK、 K_{ASME} 派生出 NAS 密钥和 K_{eNB} ，再派生 RRC/UP 密钥，实现不同用途不同密钥。

4. 分析 LTE 切换安全、前向/后向安全。

简答：后向安全是目标 eNB 不能知道过去源 eNB 通信；前向安全是源 eNB 不能知道未来目标 eNB 通信。LTE 用 NH/NCC 支持切换密钥更新。

5. 分析 LTE 用户面完整性缺口和典型攻击。

简答：LTE 用户面完整性通常可选，攻击者可能进行 DNS 欺骗、数据注入、aLTERr/IMP4GT 类攻击；认证前重定向、寻呼、去附着也可能被利用。

8.2 LTE 安全威胁

LTE 与 3G 相比，最大变化来自 eNB：

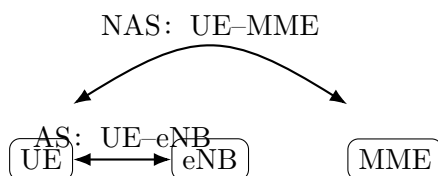
- eNB 体积小、成本低、部署在不完全可信地点。
- eNB 与核心网之间传输链路可能不安全。
- 对 eNB，尤其 home eNB，可能有物理攻击和网络攻击。
- eNB 掌握接入层密钥，若被攻破会影响用户通信。

8.3 LTE 安全要求

1. 安全性不低于 UMTS。
2. UE 与网络双向认证。
3. RRC 和 NAS 信令强制完整性保护。

4. 用户面完整性保护可选。
5. 网元之间要双向认证。
6. eNB 要安全启动, 密钥保存在安全环境中。
7. 需要不频繁执行 AKA 的密钥更新机制, 因为 USIM 计算有开销。

8.4 NAS 和 AS 分层



- NAS 安全: UE 与 MME, 保护核心网控制信令。
- AS 安全: UE 与 eNB, 保护 RRC 信令和用户面。

分层的原因: eNB 不完全可信, 不应掌握 NAS 安全密钥。

8.5 匿名机制

- GUTI: 全球唯一临时标识, 减少 IMSI 暴露。
- S-TMSI: GUTI 的缩短形式, 用于寻呼等场景。

8.6 LTE 密钥层次

$$K \rightarrow CK/IK \rightarrow K_{ASME} \rightarrow K_{NASenc}, K_{NASint}, K_{eNB} \rightarrow K_{RRCenc}, K_{RRCint}, K_{UPenc}$$

密钥层次的好处:

1. 不同用途不同密钥。
2. 控制面和用户面隔离。
3. eNB 泄露时影响受限。
4. 切换时可派生新密钥。

8.7 切换安全

手机从源 eNB 切换到目标 eNB 时, 要保证:

- 后向安全: 目标 eNB 不能破解源 eNB 过去的通信。
- 前向安全: 源 eNB 不能破解目标 eNB 未来的通信。

LTE 使用 NH 和 NCC:

- NH: Next Hop, 由 MME/UE 派生, eNB 不能自己算出。
- NCC: NH Chaining Counter, 标识密钥链更新次数。

8.8 LTE 典型缺陷和攻击

- 用户面完整性通常不强制, 可能导致 aLTER、DNS 欺骗、数据注入。
- 认证前某些重定向信令保护不足, 可能被诱导到弱网络。
- IMSI/GUTI 机制不能完全防跟踪。
- 寻呼、附着、去附着流程可能被利用造成跟踪或 DoS。
- eNB 不完全可信, home eNB 风险更大。

考场答题角度:

LTE 采用 NAS/AS 分层安全和分层密钥体系。NAS 安全保护 UE 与 MME 之间的核心网控制信令, AS 安全保护 UE 与 eNB 之间的 RRC 信令和用户面数据。由于 eNB 部署分散且处于不完全可信区域, LTE 通过密钥隔离使 eNB 只掌握接入层密钥, 而不掌握 NAS 密钥。密钥从长期密钥经 CK/IK、 K_{ASME} 派生出 NAS 密钥和 K_{eNB} , 再派生 RRC 和用户面密钥。LTE 切换安全通过 NH/NCC 等机制支持快速密钥更新, 增强前向和后向安全; 但考试中应说明其效果取决于切换方式和密钥派生方式, 不能简单写成绝对完全实现。LTE 的不足包括用户面完整性保护通常可选、IMSI/GUTI 仍可能泄露隐私、认证前信令可能被用于重定向或降级攻击。

不会写也要写的得分词:

eNB 不完全可信; NAS; AS; MME; GUTI; S-TMSI; K_{ASME} ; K_{eNB} ; NH; NCC; 前向安全; 后向安全; 用户面完整性缺口。

9 第九讲：5G 网络安全

人话理解:

5G 的重点是: 继承 4G, 再增强身份隐私、用户面完整性、切片安全、漫游安全和服务化核心网安全。

9.1 本章可能考法

1. 说明 5G 相比 4G 的安全增强。

简答: 5G 增强点包括 SUCI 身份隐藏、增强 5G-AKA、统一认证框架、用户面完整性、切片安全、SEPP 漫游安全、SBA 接口安全和设备平台可信。

2. 解释 SUPI/SUCI 和身份隐私。

简答: SUPI 是永久身份, SUCI 是用归属网公钥随机化加密后的隐藏身份。SUCI 防止空白明文暴露 SUPI, 并降低长期跟踪风险。

3. 说明 5G-AKA、密钥层次和服务网身份绑定。

简答：5G-AKA 强调归属网确认、服务网身份绑定和分层密钥派生，常见密钥有 K_{AUSF} 、 K_{SEAF} 、 K_{AMF} 、 K_{gNB} 。

4. 分析用户面完整性、切片二次认证、SEPP、SBA。

简答：用户面完整性补 LTE 缺口；切片二次认证控制用户是否能进特定行业切片；SEPP 保护跨运营商漫游边界；SBA 需 TLS、OAuth、API 鉴权和审计。

5. 分析 5G-AKA 的 SQN/可链接性问题。

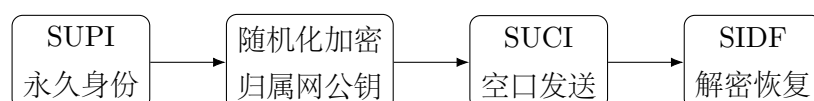
简答：SQN 或错误消息若可区分，可能让攻击者判断某用户是否存在或是否为同一用户，造成可链接性。改进是统一错误消息、引入 UE 随机数、减少 SQN 隐私泄露。

9.2 5G 安全增强

- 统一认证框架：支持 5G-AKA 和 EAP-AKA' 等。
- 增强双向认证：归属网参与最终确认，绑定服务网身份。
- 基于公钥的身份隐藏：SUPI 加密为 SUCI。
- 用户面完整性保护增强。
- 引入切片安全、SBA 安全、SEPP 漫游安全。
- 设备安全保障：安全启动、平台完整性、硬件增强密钥保护。

9.3 SUPI 与 SUCI

SUPI 是用户永久身份，类似升级后的 IMSI。SUCI 是隐藏后的身份，由 UE 使用归属网公钥对 SUPI 加密生成。



必须随机化加密。否则同一用户每次生成同样 SUCI，攻击者仍能链接和跟踪。

9.4 5G-AKA 与密钥层次

常见密钥：

- K_{AUSF} ：认证服务功能相关密钥。
- K_{SEAF} ：服务接入功能相关密钥。
- K_{AMF} ：接入和移动性管理相关密钥。
- K_{gNB} ：基站相关密钥。

答题重点不是推公式，而是写：归属网确认、服务网身份绑定、分层派生、不同用途不同密钥。

9.5 用户面完整性

LTE 用户面完整性通常不强制，5G 支持并增强用户面完整性。它尤其适合工业控制、车联网、医疗、电网等高安全业务。缺点是有性能开销，所以不一定所有业务都开启。

9.6 切片安全

网络切片就是在同一物理基础设施上切出多个虚拟网络。切片安全包括：

- 切片之间隔离。
- 用户进入切片前权限检查。
- 行业切片可做二次认证。
- 一个切片出问题不能影响其他切片。

9.7 SEPP 与漫游安全

SEPP 是 Security Edge Protection Proxy，用于保护 5G 漫游边界。它负责跨运营商信令保护、拓扑隐藏、消息过滤和完整性/机密性保护。

9.8 SBA 安全

SBA 是服务化架构，核心网网元像 API 一样互相调用。风险是接口多、攻击面大。需要：

- TLS 保护通信。
- OAuth/令牌做授权。
- API 访问控制。
- 服务发现安全。
- 日志审计。

9.9 5G-AKA 可能问题

研究中常讨论：

- SQN 同步失败消息如果可区分，可能造成用户可链接。
- 错误消息区分 MAC Failure 和 Sync Failure，可能泄露信息。
- 重复发送某些消息可能造成服务中断。
- 协议字段解释不唯一会影响形式化分析。

改进方向：统一错误消息、引入 UE 随机数、减少对 SQN 隐私依赖、明确绑定服务网身份和上下文、用形式化工具验证认证和隐私目标。

考场答题角度：

5G 在 4G 基础上增强身份隐私、认证、用户面完整性、切片和漫游安全。5G 使用 SUPI 表示永久身份，并通过归属网公钥随机化加密生成 SUCI 在空口传输，降低 IMSI/SUPI 捕获和位置跟踪风险。5G-AKA 引入 AUSF、SEAF 等功能实体，绑定服务网身份并进行分层密钥派生，增强双向认证和密钥隔离。5G 支持用户面完整性保护，弥补 LTE 用户面通常只加密不认证的不足；网络切片通过隔离和二次认证保护行业业务；SEPP 保护漫游边界；SBA 需要 TLS、OAuth、API 鉴权和日志审计。5G 仍需关注 SQN 可链接性、错误消息泄露、切片隔离和服务化接口攻击面。

不会写也要写的得分词：

SUPI；SUCI；归属网公钥；随机化加密；5G-AKA；AUSF；SEAF；AMF；用户面完整性；切片二次认证；SEPP；SBA；TLS；OAuth；SQN 可链接性。

10 第十讲：课程总结与未来无线安全

人话理解：

这章适合综合题。老师可能让你比较 2G/3G/4G/5G，或者谈未来无线网络安全。

10.1 本章可能考法

- 1. 比较 2G/3G/4G/5G 接入域安全演进。
简答：2G 单向认证和空口加密；3G 双向 AKA 和信令完整性；4G NAS/AS 分层、复杂密钥和切换安全；5G SUCI、UP 完整性、切片、SEPP、SBA。
- 2. 比较身份隐私、认证、加密、完整性、切换安全。
简答：身份从 IMSI/TMSI 到 GUTI/S-TMSI，再到 SUPI/SUCI；认证从单向到双向再到增强 AKA；完整性从无到信令完整性再到 UP 完整性增强；切换从简单重认证到 NH/NCC 密钥派生。
- 3. 谈未来无线网络的安全挑战。
简答：未来挑战包括空天地一体化拓扑变化、边缘节点暴露、海量 IoT 能力弱、切片隔离复杂、AI 被攻击、量子计算威胁。
- 4. 分析空天地一体化、边缘云、AI、切片、零信任。
简答：应采用零信任、强认证、动态密钥管理、切片隔离、可信边缘、AI 异常检测、抗量子密码和形式化协议验证。

10.2 2/3/4/5G 横向对比

系统	认证	身份隐私	加密/完整性	密钥
2G	单向认证。	IMSI/TMSI， IMSI 仍可能明文。	空口加密，无完整性。	$K_i \rightarrow K_c$ 。

3G	AKA 双向认证。	IMSI/TMSI/P-TMSI。	加密，信令完整性。	CK/IK。
4G	EPS AKA 双向认证。	IMSI/GUTI/S-TMSI。	NAS/RRC 完整性，UP 完整性可选。	K_{ASME} 、 K_{eNB} 、NH/NCC。
5G	5G-AKA/EAP 增强认证。	SUPI/SUCI。	增强 UP 完整性，切片/SBA/漫游安全。	K_{AUSF} 、 K_{SEAF} 、 K_{AMF} 、 K_{gNB} 。

10.3 加密和完整性终结点演进

- 2G：空口加密终结在 BTS/BSS 附近，缺少完整性。
- 3G：数据加密终结点在 RNC，信令有完整性。
- 4G：NAS 终结在 MME，RRC/UP 终结在 eNB。
- 5G：RRC/UP 终结在 gNB，NAS 终结在核心网，UP 完整性增强。

10.4 切换安全演进

- 2G：一般依赖重新认证或较简单上下文转移。
- 3G：根据情况选择是否重新认证。
- 4G/5G：定义完整密钥派生和切换密钥更新策略。

切换安全要在效率和安全之间平衡：每次切换都完整 AKA 开销太大；完全不更新密钥又有泄露风险。所以要用上下文转移、KDF、NH/NCC 等机制。

10.5 未来无线安全

未来网络特点：

- 空天地一体化：卫星、无人机、地面网络融合。
- 边缘云/MEC：计算下沉，边缘节点更开放。
- 海量物联网：设备多、能力弱、生命周期长。
- 网络切片：多行业共享基础设施。
- AI 智能化：AI 能检测攻击，也可能被投毒或对抗攻击。
- 抗量子：未来密码算法要考虑量子计算威胁。

10.6 未来安全方向

1. 更强认证和统一认证框架。
2. 零信任访问控制，默认不相信任何节点。
3. 切片隔离和最小权限。
4. 边缘节点可信执行和远程证明。
5. AI 辅助入侵检测、伪基站检测、异常流量分析。
6. 防 AI 投毒、对抗样本和模型窃取。
7. 形式化分析认证协议，验证认证、密钥一致性和隐私目标。

考场答题角度：

移动通信安全演进体现为从弱到强、从简单到复杂、从单一空口保护到多域协同保护。2G 主要提供单向鉴权、空口加密和临时身份，但缺少网络认证和完整性；3G 通过 AKA 实现双向认证，增加 CK/IK 和信令完整性；4G 采用 NAS/AS 分层安全和复杂密钥层次，支持快速切换密钥管理，但用户面完整性通常可选；5G 在此基础上引入 SUCI 身份隐藏、增强 5G-AKA、用户面完整性、切片二次认证、SEPP 漫游安全和 SBA 接口安全。未来无线网络将面临空天地一体化、边缘云、海量物联网、AI 和量子计算等挑战，需要零信任、切片隔离、可信边缘、AI 安全检测和形式化协议验证。

不会写也要写的得分词：

从无到有；从单向到双向；从加密到完整性；从 IMSI 到 SUCI；从简单密钥到分层密钥；从空口到切片/SBA/漫游；零信任；空天地一体化。

11 综合分析题专项模板

11.1 题型一：只加密用户面，不做完整性，不检查序列号

考场答题角度：

该方案只能提供有限机密性，不能提供完整性和新鲜性。攻击者虽然可能看不懂密文，但仍可修改、插入、删除或重放密文分组，接收方无法判断数据是否被篡改。不检查序列号会使旧数据包被重复发送并被接受，形成重放攻击。若只保护用户面而忽略控制信令，还可能导致承载建立、算法协商、切换等过程被攻击。改进时应启用用户面完整性保护或采用认证加密算法，为每个数据包加入方向、承载号、COUNT/序列号和 IV/Nonce，并将这些字段纳入 MAC；接收端维护重放窗口，拒绝重复、过期和异常乱序数据；同时区分加密密钥和完整性密钥，并定期更新。

11.2 题型二：方案使用永久身份明文接入

考场答题角度：

该方案会造成用户身份隐私泄露。无线信道开放，攻击者可被动监听永久身份，并将多次接入行为关联到同一用户，从而实现位置跟踪和用户画像。若攻击者主动搭建伪基站，还可能诱导终端重复发送永久身份。改进时应使用临时身份或加密身份，如 TMSI/GUTI/SUCI；首次接入时应尽量使用归属网公钥随机化加密永久身份；临时身份应定期更新，并在加密保护开启后重新分配；错误消息和寻呼流程也应避免暴露永久身份。

11.3 题型三：方案只有网络认证用户，没有用户认证网络

考场答题角度：

该方案属于单向认证，不能防止伪基站和中间人攻击。攻击者可以伪装成合法基站诱导终端接入，进一步获取用户身份、发起降级攻击、关闭加密或转发篡改信令。改进时应采用双向认证机制，使终端也能验证网络合法性。例如在 AKA 中通过 AUTN、MAC 和 SQN 让 UE 验证归属网生成的认证令牌；同时把服务网身份、算法协商和安全上下文纳入认证和密钥派生，防止服务网冒充和中间人攻击。

11.4 题型四：方案长期使用同一密钥

考场答题角度：

长期使用同一密钥会扩大密钥泄露影响，并增加密钥流重复和离线分析风险。若同一密钥同时用于加密、完整性和不同方向通信，还会造成一钥多用问题。改进时应通过认证密钥协商生成新鲜会话密钥，使用 KDF 派生不同用途、不同方向、不同承载的密钥，如加密密钥和完整性密钥分离，NAS/AS 密钥分离，RRC/UP 密钥分离；在切换、重认证、计数器接近上限或安全策略触发时更新密钥。

11.5 题型五：切换过程中直接把旧密钥给新基站

考场答题角度：

直接把旧密钥交给目标基站会破坏后向安全，使目标基站可能解密源基站下的历史通信；如果源基站知道目标基站未来使用的密钥，又会破坏前向安全。改进时应使用密钥派生函数从上层密钥或 Next Hop 值派生目标基站密钥，避免目标基站获得源基站旧密钥，也避免源基站知道未来密钥。LTE/5G 可使用 NH/NCC 等机制支持快速切换密钥更新，并在必要时重新认证。

最后考前速查

1. **安全目标**：认证、机密性、完整性、新鲜性、身份隐私、可用性。
2. **密码工具**：加密防偷看，MAC 防篡改，随机数/序列号防重放，KDF 做密钥分离。
3. **WLAN**：WEP 弱在 IV 短、RC4 密钥流复用、CRC 不是 MAC、静态密钥；WPA2 用四次握手和 AES-CCMP。

4. **GSM**: K_i 、RAND、SRES、 K_c 、A5; 缺点是单向认证、无完整性、IMSI 暴露。
5. **TETRA**: 双向鉴权、Class 1/2/3、SCK/DCK/CCK、空口加密、传输加密、端到端加密。
6. **WCDMA**: AKA、AV、AUTN、SQN、CK/IK、双向认证、信令完整性。
7. **LTE**: NAS/AS 分层、eNB 不完全可信、 K_{ASME} 、 K_{eNB} 、NH/NCC、UP 完整性缺口。
8. **5G**: SUPI/SUCI、5G-AKA、AUSF/SEAF、UP 完整性、切片二次认证、SEPP、SBA。
9. **未来**: 空天地一体化、MEC、IoT、切片、AI、零信任、抗量子、形式化验证。
10. **分析题**: 身份、认证、加密、完整性、防重放、密钥、切换、降级/DoS, 按这八项硬套。